CAPSTONE PROJECT: VULNERABILITY ASSESSMENT & INCIDENT RESPONSE

Date: April 9, 2026

Author: Chennari Mohammed Idris

Target System: Metasploitable 2 (Enterprise Linux Simulation)

Auditor ID: APSPL2628412

---

1. EXECUTIVE SUMMARY

This project presents an end-to-end security audit and incident response simulation on a Linux-based enterprise server. During the assessment, a Critical vulnerability was identified in the VSFTPD (v2.3.4) service, allowing for unauthenticated Remote Code Execution (RCE) with root-level privileges.

The audit successfully demonstrated the "Attack Lifecycle": from initial reconnaissance and exploitation to live detection and final system hardening. The threat was successfully neutralized using host-based firewall configurations, reducing the server's attack surface to zero for the identified vectors.

---

2. PROJECT PLANNING & METHODOLOGY

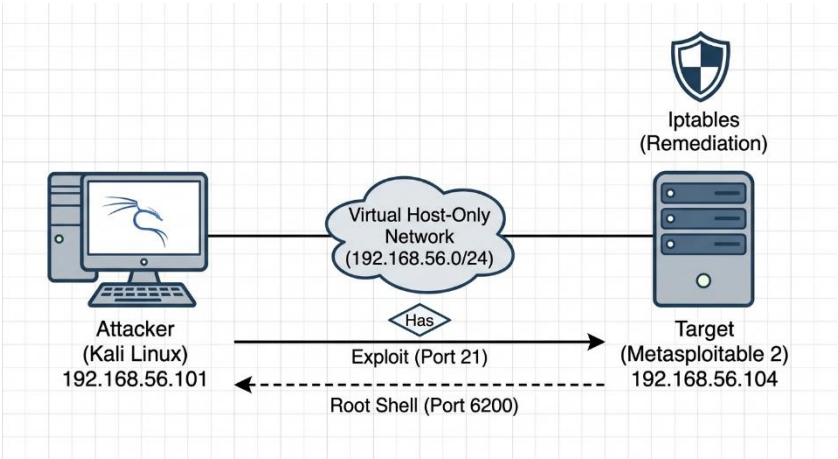
2.1 Objectives & Scope

The primary objective was to evaluate the resilience of the target server against known legacy exploits and to document a professional recovery procedure.

- Scope: Single-host audit of 192.168.56.104.
- Network Environment: Isolated Host-Only Virtual Network.

2.2 Network Architecture (ER/Network Diagram)

The following diagram illustrates the logical flow of data between the Auditor (Kali) and the Target (Metasploitable).



2.3 Toolset

- **Nmap:** Network discovery and service versioning.
- **Metasploit Framework:** Exploit execution and payload delivery.
- **Netstat**: Real-time network socket monitoring for incident detection.
- **Iptables:** Host-based firewall remediation.

---

3. TECHNICAL FINDINGS (IMPLEMENTATION)

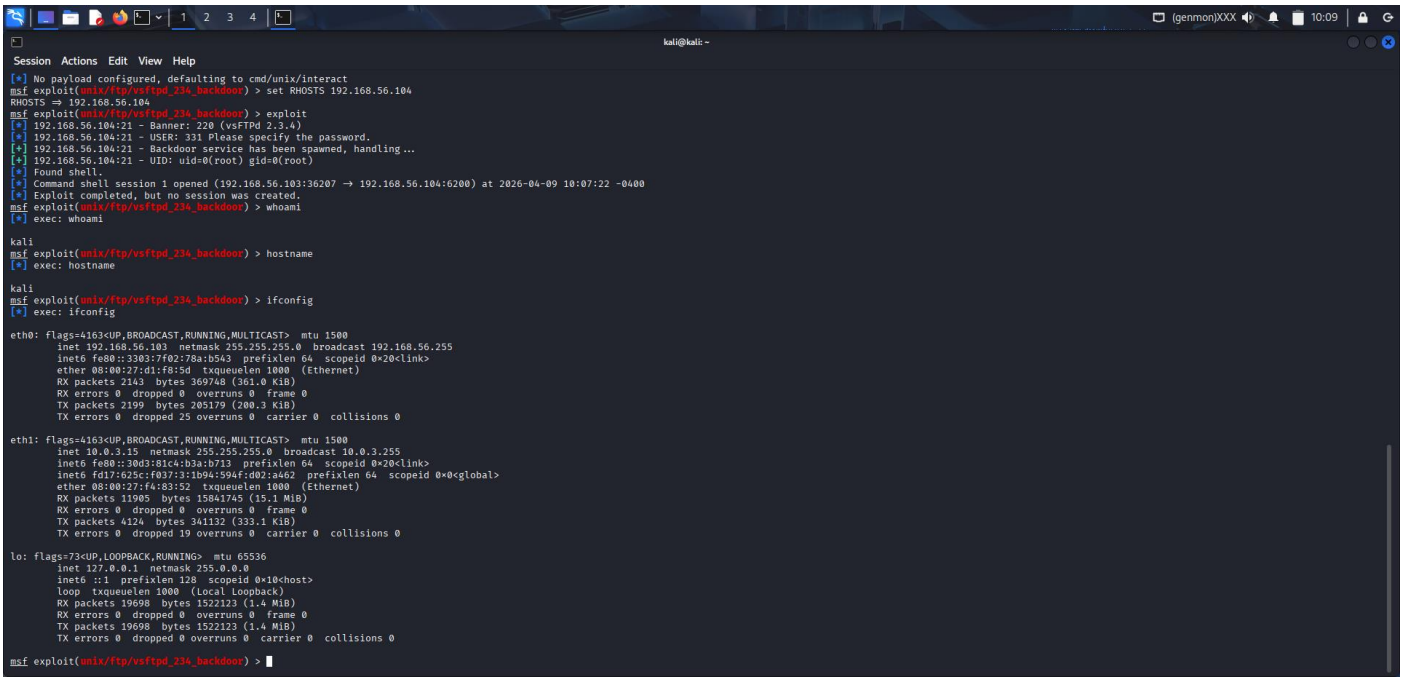
3.1 Reconnaissance & Vulnerability Identification

A service version scan revealed that Port 21 was running vsftpd 2.3.4. Historical data (CVE-2011-2523) indicates this version contains a malicious backdoor triggered by a specific character sequence.

3.2 Exploitation (The "Attack")

Using the Metasploit Framework, the backdoor was triggered, granting a high-interaction shell with root permissions.

Evidence of Root Access:



---

4. INCIDENT RESPONSE SIMULATION

4.1 Detection

The intrusion was detected by auditing active network connections. A suspicious listener was identified on Port 6200, which is the non-standard port used by the VSFTPD backdoor for command-and-control.

Evidence of Detection:

4.2 Containment & Eradication

To prevent data exfiltration, the following actions were taken:

1. The malicious process was terminated via killall.
2. The VSFTPD service was formally stopped.
3. Host-based firewall rules were applied to permanently drop traffic to Ports 21 and 6200.

5. MITIGATION & HARDENING

5.1 Post-Remediation Validation

A follow-up Nmap scan confirmed that the attack vectors are now unreachable.

Evidence of Hardening:

5.2 Long-term Recommendations

- **Patch Management:** Decommission VSFTPD v2.3.4 and migrate to a modern, supported version of OpenSSH for file transfers.
- **Principle of Least Privilege:** Disable root login over the network and implement sudo for administrative tasks.
- **Egress Filtering:** Restrict outbound traffic to only necessary ports to prevent reverse shell callbacks.

---

6. CONCLUSION

The capstone project successfully met all criteria for Task 5. By simulating both the attack and the defense, I have demonstrated the technical proficiency required to manage enterprise security incidents. The project files, including the remediation script and methodology notes, are hosted on the GitHub repository.